FINGERPRINT // DAAB7F36648FC0CA

// CONFIDENTIAL STRATEGY //

OMNIPOTENCE ENGAGEMENT ARCHITECTURE

Strategic Nexus

Strategic Security Scoping v33.0 Omni-Review

ENTITY

Global Enterprise Bank

NEXUS SCORE

70%

70

NEXUS INDEX

1.1 Engagement Coverage Index

This score reflects the breadth of technical validation across core governance pillars.

PILLAR	STATUS	PRIORITY
GOV	VALIDATED	Strategic
RES	VALIDATED	Strategic
INT	VALIDATED	Strategic
PRI	GAP	Strategic
SOV	VALIDATED	Strategic
ID	GAP	Strategic

Business Profile & Objectives

PART I.A: BUSINESS CONTEXT

ENGAGEMENT PARAMETER	CLIENT SPECIFICATION
Engagement Description	**Strategic architectural review of the core platform.**
Primary Deliverable	**Final architecture blueprint and roadmap.**

1.5 Regulatory Alignment: Global Regulated Enterprise (DORA, FRB, HKMA, PRA, MAS, APRA, NYDFS)

Narrative: A unified global compliance scoping document consolidating DORA, FRB, HKMA, PRA, MAS, APRA, and NYDFS requirements.

REGULATORY BODY — **Digital Operational Resilience Act (DORA) (European Union)**

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
Article 24	General Control Testing	ICT resilience testing programme.	Critical ICT systems.
Article 26	TLPT	Threat-led penetration testing.	Every 3 years for critical entities.

Mandatory Evidence Artifacts:

Asset Register | Threat Scenarios | TI Plan | Remediation Plan

IMPLEMENTATION GUIDANCE — **DORA**

ICT Asset Criticality Mapping

Under DORA, scoping must start with the ICT Asset Register. Every asset in scope must be mapped to a 'Critical or Important Function' (CIF). If an asset supports a CIF, it is subject to more rigorous testing and reporting requirements.

Third-Party ICT Risk

DORA requires that testing includes third-party ICT service providers where they support critical or important functions. This scoping pack must include a list of involved third parties and confirmation of their authorization to test.

Threat Intelligence Requirements

For TLPT (Threat-Led Penetration Testing), the scope must be driven by current, relevant threat intelligence. The scenarios defined in this pack should match the TTPs of actors targeting the financial sector.

REGULATORY BODY — **Federal Reserve Board (FRB) Supervision (United States)**

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
SR 13-1	Supplemental Policy Statement on the Internal Audit Function	Independent testing of security controls.	Risk-based coverage.

Mandatory Evidence Artifacts:

Independent Review | Mgmt Response | Prior Findings Remediation

IMPLEMENTATION GUIDANCE

FRB

SR 13-1 / Vendor Risk

The scoping must encompass critical third-party vendors and external facing infrastructure in alignment with FRB supervision expectations.

REGULATORY BODY

Hong Kong Monetary Authority (HKMA) iCAST (Hong Kong)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
CFI	Intelligence-led Cyber Attack Simulation	Perform intelligence-led simulated attacks.	Threat intelligence derived simulation.

Mandatory Evidence Artifacts:

Threat Intelligence Report | Execution Log | Remediation Plan

IMPLEMENTATION GUIDANCE

HKMA

iCAST Execution

Simulations must cover the 'Assume Breach' methodology to assess the detection and response capabilities of the institution's Security Operations Center (SOC).

REGULATORY BODY

Prudential Regulation Authority (PRA) CBEST (United Kingdom)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
CBEST	Intelligence-led Penetration Testing	Employ external/internal threat-led penetration testing.	System-specific critical boundary.

Mandatory Evidence Artifacts:

Targeted Threat Intelligence | Test Plan | Execution Report | Control Effectiveness Summary

CBEST Intelligence-Led Testing

Testing must be driven by bespoke threat intelligence targeting the specific critical business services (CBS) of the UK financial institution.

REGULATORY BODY

Monetary Authority of Singapore (MAS) TRM (Singapore)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
Section 12	Vulnerability Assessment and Penetration Testing	Conduct comprehensive VAPT on critical IT systems.	Annually or upon major changes.
Section 13	Cyber Incident Response	Simulate adversary attacks to test detection and response.	Red team exercises for major institutions.

Mandatory Evidence Artifacts:

VAPT Report | Red Team Execution Log | Root Cause Analysis

REGULATORY BODY

Australian Prudential Regulation Authority (CPS 234) (Australia)

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
Paragraph 31	Testing Control Effectiveness	Systematic testing programs for information security controls.	Commensurate with the rate of threat change.

Mandatory Evidence Artifacts:

Security Control Testing Schedule | Control Deficiencies Log | Assurance Report

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
500.05	Penetration Testing and Vulnerability Assessments	Annual penetration testing and bi-annual vulnerability assessments.	Must cover the entire information system.

Mandatory Evidence Artifacts:

Annual Certification | Penetration Testing Report | CISO Report

IMPLEMENTATION GUIDANCE

MITRE

T1190 - Exploit Public-Facing Application

Adversaries may attempt to take advantage of a weakness in an Internet-facing computer or program using software, data, or commands in order to cause unintended or unanticipated behavior.

T1078 - Valid Accounts

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.

T1566 - Phishing

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering.

T1059 - Command and Scripting Interpreter

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries.

IMPLEMENTATION GUIDANCE

OWASP

A01:2021-Broken Access Control

Testing must validate that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification, or destruction of all data.

A02:2021-Cryptographic Failures

Testing must verify the protection of sensitive data in transit and at rest. This includes passwords, credit card numbers, health records, personal information, and business secrets.

A03:2021-Injection

Testing must validate that user-supplied data is not interpreted as commands or queries (e.g., SQL, NoSQL, OS command, ORM, LDAP, and EL expression or OGNL injection).

A04:2021-Insecure Design

Testing must evaluate the architectural design for missing or ineffective control design. Insecure design cannot be fixed by a perfect implementation.

Control 1: Inventory and Control of Enterprise Assets

Actively manage (inventory, track, and correct) all enterprise assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments.

Control 4: Secure Configuration of Enterprise Assets and Software

Establish and maintain the secure configuration of enterprise assets and software.

Control 12: Network Infrastructure Management

Establish, implement, and actively manage network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

2.1 Digital Chain of Evidence

Artifacts produced during this engagement follow a cryptographically-verifiable lifecycle.

LIFECYCLE PHASE	VALIDATION METHOD
Acquisition	SHA-256 Verified Capture
Processing	Air-Gapped Analysis Environment
Destruction	NIST 800-88 Compliant Wipe

2.2 Data Sovereignty & Residency

To adhere to regulatory data protection requirements, the following residency rules apply to all engagement artifacts.

FRAMEWORK	RESIDENCY MANDATE
DORA	Must remain strictly within EU boundaries or approved adequate jurisdictions. Cloud storage requires EU-based tenants.
FRB	Federal regulatory artifacts must be accessible on-shore within the United States.
HKMA	Assessment data should preferably be stored locally in Hong Kong in accordance with HKMA guidelines.
PRA	All testing artifacts and raw execution logs must remain strictly within the United Kingdom.
MAS	Financial data and assessment details must comply with Singapore PDPA and MAS Outsourcing Guidelines (on-shore processing preferred).
APRA	Strictly on-shore data storage; offshore processing of CPS 234 artifacts requires explicit APRA notification/approval.
NYDFS	Data must be protected under strict encryption standards; artifacts must be readily available to the Superintendent.

2.3 Regulator Audit & Access Rights

The following audit rights and access privileges are contractually granted to the respective regulatory bodies.

REGULATOR	ACCESS RIGHTS
DORA	European Supervisory Authorities (ESAs) must have full and unrestricted access to threat-led penetration testing results.
FRB	Federal Reserve examiners possess unrestricted rights to review working papers and final security deliverables.
HKMA	HKMA retains the right to directly review the threat intelligence models and execution logs.
PRA	PRA and FCA maintain joint audit rights over the testing methodology, control mappings, and CBEST deliverables.
MAS	MAS requires immediate notification of critical vulnerabilities and right-to-audit for independent assessments.
APRA	APRA reserves the right to request independent security assessments and review all control deficiencies.
NYDFS	The NYDFS Superintendent has absolute authority to audit the CISO's annual compliance certification and testing reports.

Technical Scope of Work

PT-NET-EXT

External Network Penetration Test

A structured assessment of internet-facing infrastructure including firewalls, VPNs, mail gateways, and publicly reachable hosts. Testers simulate real-world attackers attempting to gain unauthorised access from outside the perimeter. Findings are rated by exploitability and business impact.

2 Days | €3,500 Budgetary ALLOC

PT-APP-WEB

Web Application Penetration Test

Manual-led security testing of web applications aligned to the OWASP Top 10 and WSTG, covering injection flaws, broken authentication, sensitive data exposure, XML external entities, broken access control, security misconfigurations, XSS, insecure deserialisation, and business logic vulnerabilities.

3 Days | €4,000 Budgetary ALLOC

PT-APP-API

REST/GraphQL API Security Testing

Targeted assessment of REST, SOAP, and GraphQL APIs using the OWASP API Security Top 10 framework. Covers broken object-level authorisation, excessive data exposure, lack of rate limiting, broken function-level authorisation, mass assignment, security misconfiguration, and injection flaws.

2 Days | €3,500 Budgetary ALLOC

RT-FULL

Full Red Team Engagement

An adversary simulation engagement where a dedicated red team uses realistic threat actor TTPs to attack the organisation across all vectors — digital, physical, and human — without prior disclosure to defenders. Measures the organisation's detection, response, and containment capabilities.

17 Days | €25,000 Budgetary ALLOC

PT-CLD-INF

Cloud Infrastructure Penetration Test

Assessment of cloud-native infrastructure, IAM, and resource configurations.

3 Days | €5,000 Budgetary ALLOC

Omni Control Matrix

3.1 Omni Control Mapping

The following granular controls are in scope for the selected execution modules.

CONTROL ID	DOMAIN	DESCRIPTION
AC_01	None	None
IA_02	None	None
SI_04	None	None

RACI Governance

3.2 RACI Governance Matrix

Responsibility Assignment Matrix for engagement activities.

ACTIVITY	PROVIDER	CLIENT SEC LEAD	CLIENT IT	CLIENT EXEC
Project Kick-off	**R**	**A**	**C**	**I**
Access Provisioning	**C**	**I**	**R**	**A**
Technical Testing	**R**	**A**	**I**	**C**
Report Delivery	**R**	**A**	**C**	**I**
Remediation Sign-off	**C**	**I**	**R**	**A**

Verification & Sign off

NEXUS SEAL

Executive Sponsor Approval

Lead Strategic Provider

FINGERPRINT // DAAB7F36648FC0CA7F5BF112FA8B91EF3508764B2F2CDE83639D4AB6912B0FD4

Engagement Sign-Off

By signing below, the client agrees that this unified scoping document satisfies the engagement coverage requirements for DORA, FRB, HKMA, and PRA compliance regimes.

Executive Sponsor: _____

Date: _____